

PayGate — Security One-Pager

Project: PayGate · Sovereign payment + identity layer for AI agents | **Track:** BUIDL_QUESTS 2026 — Sovereignty | **Contract:** 0xb4Da3B8300881E0d84f269D1Bc3BBc03839c242A on Base Sepolia

Status: v0.1.0, not yet audited. Pre-mainnet recommendations in docs/SECURITY.md.

What PayGate is

x402 (Coinbase, May 2025) lets AI agents pay each other USDC over HTTP. PayGate is an x402 wrapper that adds three primitives x402 doesn't have: **on-chain identity** (ERC-8004), **on-chain spending policy**, and a **one-transaction kill switch**.

Threat model

Component	Trust	PayGate's response
Compromised agent wallet	Untrusted (assumed)	Caps enforced at the contract, not the SDK
Compromised agent SDK	Untrusted	Policy is in SpendingPolicy.recordSpend() — reverts on cap
Compromised human owner	Medium	Operational risk (rotate wallet, cold storage)
x402 facilitator lies	Medium	wrap() awaits on-chain receipt before running handler
ERC-8004 registry upgrade	Low (high-trust multisig)	Out of PayGate's scope; affects all consumers

Mitigations for the 5 known x402 attacks (arXiv:2605.11781)

#	Attack	PayGate mitigation
1	Grant-before-settle	Settle via facilitator, await on-chain receipt, then run handler
2	Missing resource-identifier binding	402 'resource' field = request path; EIP-3009 auth is path-bound
3	Fire-and-forget settlement	Synchronous /settle + waitForTransactionReceipt; 200 not sent until confirmed
4	Missing Cache-Control	Every 402 and 200 includes Cache-Control: no-store
5	Replay	EIP-3009 single-use nonce + SpendingPolicy epoch counter + per-call cap

Smart contract security controls

- **OpenZeppelin 5.x Ownable(msg.sender):** explicit initial-owner pattern (no silent ownership)
- **ReentrancyGuard:** on all state-modifying functions in both contracts
- **Custom errors:** all 9 revert paths are named (NotOwner, Paused_, ExceedsPerCallLimit, etc) — no string reverts
- **onlyAgentOwner modifier:** a random address cannot pause someone else's agent
- **Per-agent SpendingPolicy:** owned by the registry, not the human — clean privilege separation
- **Hardhat test suite:** 13/13 tests pass (register, rotate, deactivate, canSpend, recordSpend, etc)
- **On-chain smoke test:** 7/7 checks pass on Base Sepolia with the deployed v2 contract
- **Live + verified:** 0xb4Da3B8300881E0d84f269D1Bc3BBc03839c242A on Base Sepolia (chain 84532)

What's NOT yet protected (acknowledged in SECURITY.md)

- No two-step rotatewallet handover — front-running possible. Planned for v0.2.
- Allowlist is a mapping + bool flag, not enumerable.
- No formal verification or external audit yet.
- No batched settlement (multi-spend in one tx).
- Compromise of the human owner's key is operational risk, not contract risk.

Pre-mainnet audit recommendations

- Two-step wallet rotation (mitigates front-running)
- Add EpochReset event for setLimits (observability)
- Replace single-bool `_allowlistStrict` with enumerable set
- External audit by Halborn (BUIDL_QUESTS co-sponsor) — targeted for post-hackathon
- Formal verification of the spending-policy invariants (Certora or similar)
- Fuzz testing of `wrap()` and `call()` flows (Echidna / Foundry invariant testing)

Disclosure

Security issues: open a GitHub issue at github.com/Donyemiight/paygate/issues with the label **security**. Response within 48 hours.

TL;DR

PayGate turns x402 from "agents can pay each other" into "agents can pay each other, the human stays in control, and a compromised agent can be paused in 1 transaction." The contract is small (2 files, ~250 LOC), tested, and live. Full threat model + audit recommendations in `docs/SECURITY.md`.